

PARA O ALTO E AVANTE

INTRODUÇÃO THREAT HUNTING



8

LISTA DE FIGURAS

Figura 1 – Um processo típico de caça às ameaças.....	8
Figura 2 – IOC.....	12
Figura 3 – IOCs e IOAs	13
Figura 4 – <i>Cyber Kill Chain</i> ®.....	16
Figura 5 – <i>Unified Kill Chain</i>	18
Figura 6 – Tipos de Inteligência de Ameaças.....	21
Figura 7 – Matriz ATT&CK	23
Figura 8 – Matriz Mobile	23
Figura 9 – PRE Matriz ATT&CK	24
Figura 10 – Modelo ATT&CK	24
Figura 11 – Técnica de manipulação de contas	25
Figura 12 – ATT&CK e <i>Cyber Kill Chain</i> ®.....	25

LISTA DE QUADROS

Quadro 1 – Referências para IOC.....	12
--------------------------------------	----

EMANIP

SUMÁRIO

1 INTRODUÇÃO THREAT HUNTING	5
2 METODOLOGIAS DE CAÇA ÀS AMEAÇAS	5
2.1 Investigação baseada em hipóteses	6
2.2 Investigação baseada em indicadores de comprometimento ou indicadores de ataque	6
2.3 Investigação com análise avançada e aprendizado de máquina	6
3 PROCESSOS PARA CAÇA ÀS AMEAÇAS	6
3.1 O gatilho – preparação	7
3.2 A investigação – detecção e análise	7
3.3 A resposta – resolução do problema	7
4 TERMOS	8
4.1 APT	9
4.2 TTP	10
4.3 IOC	11
4.4 IOA	13
4.5 EDR	13
5 CYBER KILL CHAIN	15
5.1 <i>Reconnaissance</i>	16
5.2 <i>Weaponization</i>	17
5.3 <i>Delivery</i>	17
5.4 <i>Exploitation</i>	17
5.5 <i>Installation</i>	17
5.6 <i>Command & Control</i>	17
5.7 <i>Actions on Objectives</i>	18
6 THREAT INTELLIGENCE	18
6.1 Ciclo de vida	19
6.1.1 Requisitos	19
6.1.2 Coleta	19
6.1.3 Processamento	20
6.1.4 Análise	20
6.1.5 Disseminação	20
6.1.6 Retorno	20
7 TIPOS DE INTELIGÊNCIA DE AMEAÇAS	20
7.1 Tática	21
7.2 Operacional	21
7.3 Estratégica	22
8 MITRE ATT&CK	22
CONCLUSÃO	26
REFERÊNCIAS	27
GLOSSÁRIO	29

1 INTRODUÇÃO THREAT HUNTING

Os caçadores de ameaças são especialistas que trabalham em uma atividade de pesquisa proativa para detectar e mitigar ameaças. Essa área é conhecida como “Caça às Ameaças” ou, em inglês, *Threat Hunting*. Seu foco é encontrar agentes mal-intencionados que conseguem ultrapassar as barreiras de proteções já implantadas, no caso de uma rede de computadores: *firewalls*, antivírus, sistemas de detecção de intrusão (IDS), sistemas de prevenção a intrusão (IPS), etc.

Após um atacante conseguir contornar todas as proteções implantadas, ele invade a rede de uma organização. Muitos desses alvos não possuem recursos avançados de detecção para impedir que as ameaças persistentes avançadas (APT) permaneçam na rede, e é por isso que a caça às ameaças é um componente crucial para a estratégia de defesa.

Esses especialistas trabalham como se a rede já estivesse comprometida e o atacante permanecesse nela de maneira furtiva observando e conhecendo os alvos para efetuar a coleta de dados, à procura de conteúdo confidencial ou a fim de obter credenciais válidas em sistemas corporativos para efetuar algum movimento lateral e tentar conseguir mais acesso.

2 METODOLOGIAS DE CAÇA ÀS AMEAÇAS

Os caçadores de ameaças trabalham com a ideia de que os atacantes já estão nos sistemas, então iniciam uma busca por comportamentos anômalos que possam indicar a presença de atividades maliciosas não detectadas pelos meios tradicionais do Centro de Operações de Segurança (SOC).

O início de uma investigação normalmente se enquadra em três categorias principais: baseada em hipóteses, baseada em indicadores de comprometimento ou indicadores de ataque e análise avançada e investigações com aprendizado de máquina.

Todas essas categorias são esforços combinados de recursos de inteligência de ameaças e segurança avançada para proteger os sistemas e as informações de uma organização de maneira proativa.

2.1 Investigação baseada em hipóteses

Esse tipo de investigação é frequentemente iniciado quando uma nova ameaça é identificada por meio de uma grande massa de dados em um ataque coletivo, geralmente feito por empresas especializadas que possuem diversos ativos espalhados pelo mundo, e através desses dados são obtidas informações sobre táticas, técnicas e procedimentos (TTP) mais recentes dos invasores. Quando um novo TTP é identificado, os caçadores de ameaças procuram esses comportamentos na rede.

2.2 Investigação baseada em indicadores de comprometimento ou indicadores de ataque

Essa metodologia envolve o aproveitamento dos dados da inteligência tática sobre ameaças que foram utilizados para a criação de indicadores de comprometimento (IOC) e indicadores de ataque (IOA). Esses indicadores podem ser associados a novas ameaças que surgirem, pois muitas delas se utilizam de recursos já conhecidos para efetuar novos ataques.

2.3 Investigação com análise avançada e aprendizado de máquina

Nesse ponto, a análise de dados coletados e o aprendizado de máquina são combinados de maneira que os especialistas consigam filtrar uma quantidade de informação a fim de detectar anomalias que podem sugerir uma atividade maliciosa. Essas informações se tornarão pistas que serão investigadas por especialistas.

3 PROCESSOS PARA CAÇA ÀS AMEAÇAS

A caça às ameaças cibernéticas geralmente envolve três etapas: o gatilho, a investigação e a resposta.

3.1 O gatilho – preparação

Algumas organizações possuem uma programação para busca de ameaças em sua rede, mesmo que não tenham uma causa concreta. A suspeita de alguma das equipes de proteção sobre a hipótese de uma nova ameaça também pode ser um gatilho para ativar a equipe.

Geralmente quando uma das ferramentas de detecção identifica ações incomuns na rede, em um segmento da rede ou em um sistema específico, pode ser indício de que alguma atividade maliciosa está ocorrendo.

Um dos gatilhos mais corriqueiros são ações incomuns na rede, pois constantemente as outras equipes podem detectá-las e solicitar sua análise.

Os especialistas se atualizam de maneira constante a respeito de novos tipos de ameaças que estão surgindo a fim de estarem preparados para, com outras equipes, efetuarem o rastreo e a investigação de possíveis atividades que ponham em risco a segurança de sua rede.

3.2 A investigação – detecção e análise

Durante essa fase, a equipe de caça às ameaças usa algumas ferramentas como: EDR (*Endpoint Detection and Response*) e SIEM (*Security Information and Event Management*), para fazer uma análise profunda sobre as ações incomuns que estão acontecendo na rede ou no sistema. A investigação continua até que a equipe tenha sua hipótese confirmada e obtenha uma análise completa do comportamento malicioso ou até que o comportamento detectado seja considerado benigno.

3.3 A resposta – resolução do problema

Essa etapa envolve a troca de informações relevantes sobre as atividades detectadas, sejam elas maliciosas ou não, com a equipe de operações e de inteligência de ameaças, proporcionando rapidez nas ações de mitigação de riscos e análise das informações encontradas.

Uma boa documentação sobre tudo que foi detectado e analisado em relação à ameaça permite que a organização faça uma análise melhor e consiga prever comprometimentos semelhantes no futuro.

Os dados coletados sobre essas atividades, sejam elas malignas ou benignas, podem ser inseridos em uma tecnologia automatizada. Esse registro servirá como um suporte rápido e eficaz para identificar e apresentar soluções baseadas nos parâmetros utilizados anteriormente em situações semelhantes. Dessa forma, são economizados tempo e recursos, pois será necessária uma menor intervenção humana.

Ao longo desse processo, a equipe de caça às ameaças cibernéticas reúne o máximo de informações sobre ações, métodos e objetivos do possível invasor.

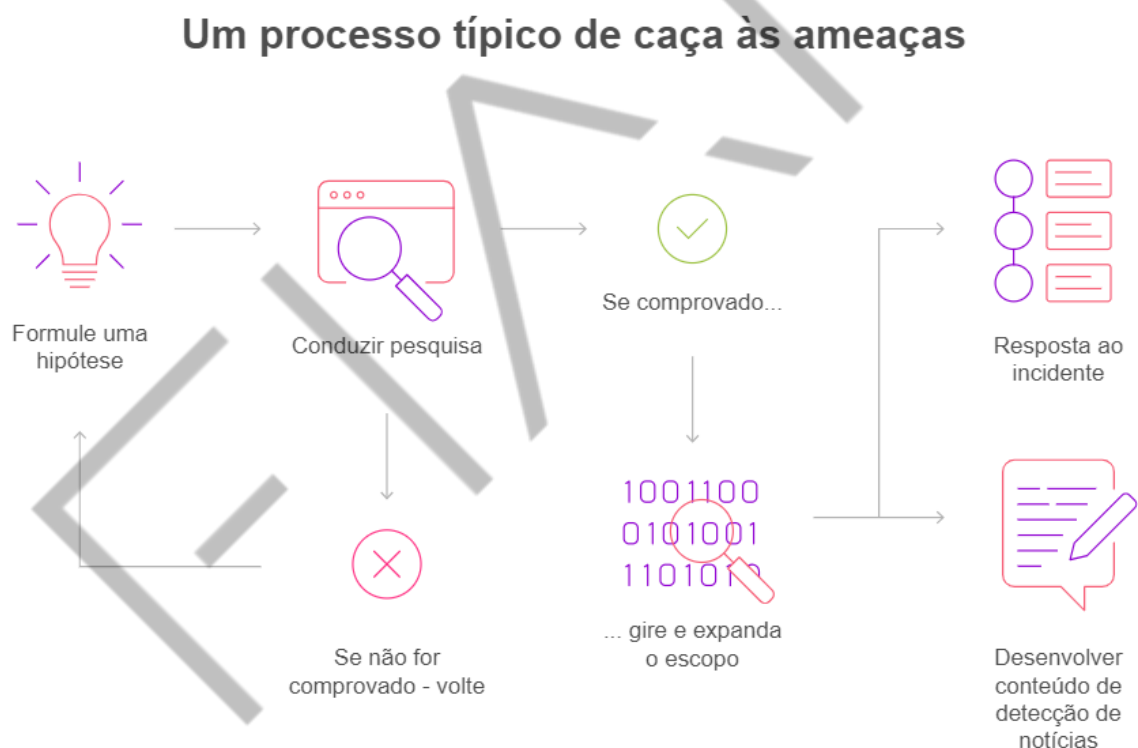


Figura 1 – Um processo típico de caça às ameaças
Fonte: LogPoint (2021)

4 TERMOS

Um profissional da área de caça às ameaças precisa estar familiarizado com alguns termos que serão utilizados no decorrer de sua carreira. Neste tópico, veremos os principais utilizados.

4.1 APT

APT é a abreviatura de *Advanced Persistent Threat* (Ameaça Persistente Avançada). Diferentemente dos criminosos virtuais, os APTs não estão interessados em atingir a maior quantidade de computadores para buscar credenciais de bancos, contas ou outros dados do usuário com a intenção de conseguir dinheiro ou outros benefícios.

Os APTs são grupos interessados em atingir um computador ou um grupo específico, sendo que alguns desses grupos podem até ser patrocinados pelo Estado, mas sem vínculo estatal. O objetivo final de um ataque desses é atingir um dispositivo específico, em busca de informação valiosa para quem o patrocina ou completar uma determinada missão.

Para atingir seu objetivo final geralmente são utilizados outros dispositivos que estão menos protegidos ou pessoas que poderão ser mais suscetíveis a clicar em algum arquivo malicioso que, em sua maioria, é enviado por e-mail.

Esses e-mails não são como os que recebemos diariamente. Eles são direcionados para uma pessoa específica ou para um determinado grupo de pessoas que possam ter contado com o seu alvo final.

Para evitar que esses ataques sejam bem-sucedidos, as empresas devem investir em produtos de segurança corporativa, educação cibernética e bons profissionais da área de segurança.

Mas não apenas funcionários de empresas são alvos de ataques desses grupos. Tudo dependerá do seu objetivo final, como pode ser lido abaixo:

[...] especialistas do Securelist descobriram uma campanha de espionagem APT chamada "NetTraveler" que pode ter durado mais de uma década, atingindo diplomatas, oficiais militares e órgãos governamentais de mais de 40 países. Esse ataque, como muitos outros do estilo APT, começou com um e-mail de spear-phishing que explorou algumas vulnerabilidades de Microsoft. Desenvolveram uma ferramenta capaz de extrair informação do sistema, baixaram um malware de keylogging, roubaram documentos Office como arquivos Word, Excel e PowerPoint, modificaram as configurações para obter arquivos Corel Draw, AutoCAD e outros tipos de arquivos usados em processos de produção. Esses ataques devem ser considerados do tipo APT porque parecem ter sido direcionados apenas a indivíduos e organizações cujos computadores poderiam conter segredos valiosos. Como mencionado acima, APT também pode se referir a hackers ou grupos agressores (DONOHUE, 2013).

Os grupos utilizam falhas críticas dos sistemas da rede alvo para desenvolver suas ferramentas. Muitas vezes se utilizam de falhas chamadas “*Oday*” para não serem detectados facilmente e conseguem persistir na rede por diversos dias ou até mesmo meses.

O termo *Oday* é utilizado quando são encontradas falhas no software para as quais o desenvolvedor ainda não lançou atualizações de segurança a fim de corrigi-las. Também pode ser escrito das seguintes formas: *O-day*, *zeroday* e *zero-day*.

A empresa *Fireeye* atualiza constantemente uma lista dos principais grupos APTs identificados, bem como algumas informações sobre eles: <https://www.fireeye.com/current-threats/apt-groups.html>.

4.2 TTP

TTP é a sigla para Táticas, Técnicas e Procedimentos. No geral, auxiliam a criar uma identidade para uma atividade maliciosa. Nessa abordagem, é feito um levantamento detalhado do tipo de ação utilizada no ataque, do modo que as ferramentas necessárias para a execução atuam e de como as técnicas são executadas. Por exemplo, Acesso de Credencial (T) → Despejo de Credencial de Sistema Operacional com *Mimikatz* (T) → Utilização da ferramenta por meio de terminal remoto para leitura das credenciais armazenadas em memória (P).

Essa abordagem é eficaz porque a atividade maliciosa se limita a uma quantidade e a tipos de técnicas que eles podem utilizar para atacar o sistema alvo.

Por exemplo, para atacar o sistema operacional Windows, os atacantes utilizam procedimentos que exploram as vulnerabilidades de serviços existentes para essa plataforma, verificando o serviço de compartilhamento de arquivos, a área de trabalho remota, os protocolos proprietários da Microsoft, etc.

Caso algum ativo da sua rede ou algum endereço externo tente várias vezes efetuar a conexão nesses serviços, é provável que seja uma tentativa de ataque. Antes de efetuar algum ataque, no geral, os *malwares* verificam se é possível estabelecer uma conexão com a porta do serviço; caso ela esteja aberta, os próximos passos são efetuados.

4.3 IOC

IOC ou Indicador de Comprometimento (*Indicator of Compromise*) é um conjunto de parâmetros de referência para indicar se um sistema sofreu alguma atividade maliciosa ou suspeita.

Veja, a seguir, um quadro com exemplos de referências que podem ser utilizadas na área de segurança cibernética e os motivos para serem usadas.

Referência	Motivo
Processo	Os <i>malwares</i> se utilizam de falhas em aplicações e serviços. Depois que essas falhas são exploradas, iniciam-se alguns processos para disseminar ou executar ações específicas, geralmente com ferramentas padrão do sistema operacional alvo.
Nome do Arquivo	Vários <i>malwares</i> possuem nomes conhecidos, geralmente são bem parecidos com a denominação de processos legítimos do sistema.
<i>Hashes</i>	São identificadores que servem para identificar um conjunto de dados. São gerados por algoritmos e podem ser comparados para verificar se os dados são os mesmos ou se houve alterações. Alguns desses algoritmos possuem problemas de colisão, por isso é ideal que sejam gerados vários <i>hashes</i> com algoritmos diferentes.
Endereços de IP	Alguns <i>malwares</i> efetuam conexões com alguns endereços de IPs preestabelecidos, seja para comando e controle, seja para checagem de conexão.

Nomes de <i>host</i>	Além de endereços de IP, os <i>malwares</i> se utilizam de nome do <i>host</i> para resolver via DNS e efetuarem as conexões necessárias.
<i>Logs</i> de eventos	É possível encontrar vestígios de dados deixados para trás por meio dos <i>logs</i> .
Chave de registro	Alterações em algumas chaves de registro para habilitar e desabilitar serviços.
Chamadas de API	Bibliotecas de sistemas são bastante utilizadas por <i>malwares</i> na tentativa de se esconderem das ferramentas de segurança.

Quadro 1 – Referências para IOC
Fonte: Elaborado pelo autor (2021)

Essas referências geralmente são divulgadas por vários sites de segurança e não costumam ser alteradas.

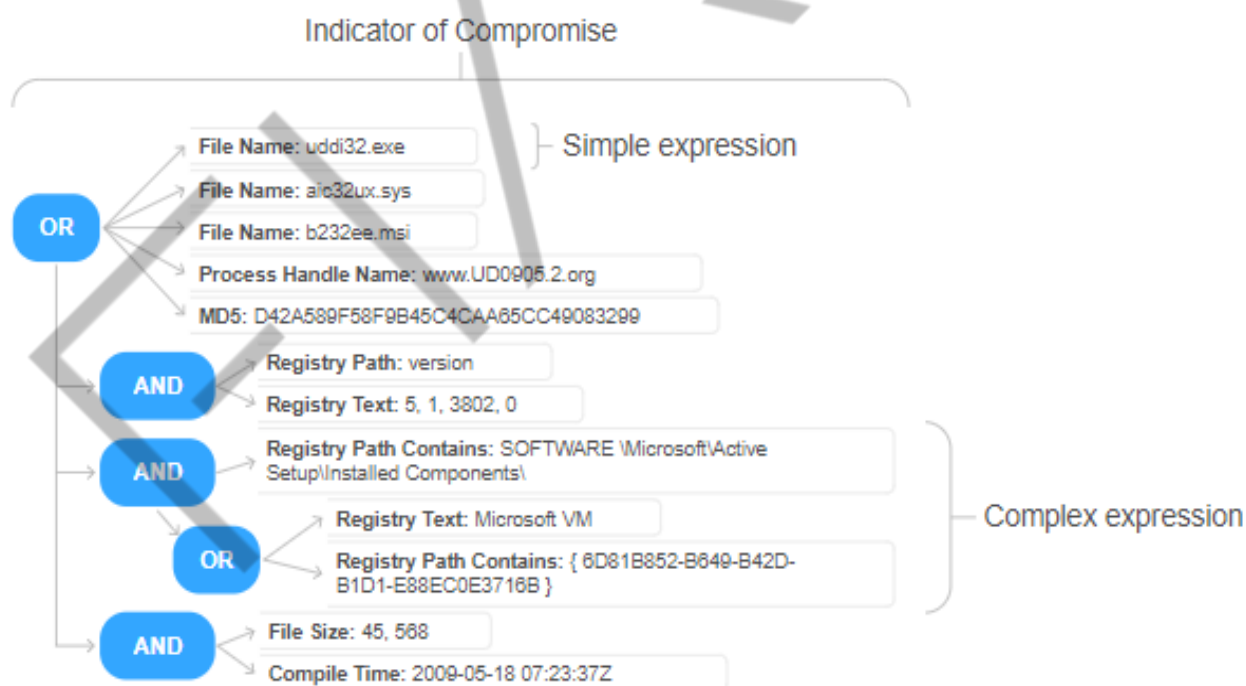


Figura 2 – IOC
Fonte: FireEye (2021)

Entretanto, não devemos afirmar que uma máquina está infectada por conta dos IOCs; deve ser feita uma análise mais profunda para confirmar a ameaça.

4.4 IOA

Abreviação para Indicador de Ataque (*Indicator of Attack*), que é definido como a detecção do objetivo do atacante (tática) e a operação técnica (técnica) sobre como atingir o objetivo final. Assemelha-se às soluções baseadas em assinaturas dos antivírus. Muito útil para *malwares* que não geram arquivos em disco, ou seja, que são executados diretamente em memória e os *malwares* que utilizam *Oday*.

Outra grande diferença é que os IOAs podem detectar ataques que não utilizam *malwares*, que são aqueles com base apenas em tática e técnicas do atacante, pois eles utilizam ferramentas e procedimentos que, para o sistema operacional, são legítimos e confiáveis.

Os IOAs são observados em tempo real: assim que as ações são realizadas, as ferramentas e os profissionais detectam algumas atividades que podem estar sendo executadas por alguém com intenções maliciosas.

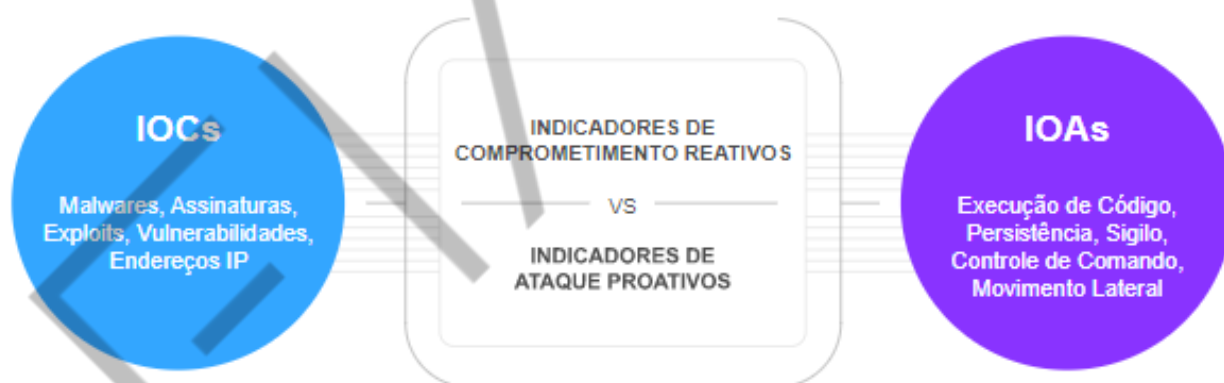


Figura 3 – IOCs e IOAs
Fonte: CrowdStrike (2021)

Combinando os IOCs com os IOAs de um artefato malicioso, é possível enriquecer nosso programa de monitoramento de ameaças encontrando-os rapidamente para tomar as devidas ações de contenção e resolução.

4.5 EDR

Os EDR, ou *Endpoint Detection and Response*, têm a capacidade de detectar e remover ou mitigar a ação de *malware* em *endpoints* da rede. *Endpoints* são dispositivos de “final de linha”, ou seja, dispositivos conectados a uma rede, como

computadores, *switches*, roteadores, impressoras, dispositivos móveis inteligentes, entre outros.

Esses sistemas ajudam a rastrear IOC e IOAs, coletando dados que podem ser utilizados para uma análise mais profunda sobre as ações realizadas ou suas tentativas, podendo integrar algumas outras soluções de segurança para mais detalhes.

Basicamente, existem os EDRs que necessitam de agente instalado no dispositivo e os que não necessitam. Quando precisamos instalar um agente, ele deve ser compatível com o sistema operacional do dispositivo. Já os EDR que não precisam de agente instalado utilizam informações recebidas por meio da rede ou de outras ferramentas de segurança.

O agente é um software que se comunica com o EDR, ou seja, ele coleta e transmite os dados para um servidor central e é possível utilizar recursos para rastreamento da atividade do usuário, podendo intervir e colocar o dispositivo em quarentena se alguma atividade maliciosa for detectada, além de permitir algumas correções para uma rápida contenção.

Do outro lado, temos os EDRs que não precisam de agente instalado. Estes se utilizam de informações que podem ser provenientes de outras soluções de segurança, mas, por padrão, utilizam as informações do tráfego de dados que passam entre os ativos da rede. Ele pode isolar esses dados da rede, porém não será possível detectar arquivos maliciosos nos dispositivos, caso esses *malwares* não tenham sido executados ou não gerem tráfego na rede.

Os EDRs podem trabalhar dessas duas formas. A segunda (sem agente) é muito utilizada nos trabalhos remotos, já que os funcionários usam seu próprio dispositivo para acessar a rede local da empresa, não sendo instalado o agente no dispositivo do funcionário. Assim, há apenas captura do tráfego que é direcionado para a rede da organização.

Existem empresas de segurança que disponibilizam um serviço em nuvem para armazenamento dos dados coletados, facilitando sua análise de qualquer lugar em que haja acesso à Internet. Além desse serviço, os IOCs e os IOAs podem ser atualizados diretamente da base de dados da empresa em que o software EDR foi contratado.

Boas ferramentas de EDR permitem que as equipes de segurança da organização insiram os seus indicadores e construam uma base de informações específicas para determinada organização, pois, nesse ambiente, alguns indicadores podem mostrar alguma ação maliciosa.

Ao procurar alguma ferramenta desse tipo, é ideal que ela contenha recursos de relatórios e um painel para que as decisões do nível executivo sejam tomadas sem a necessidade de informações técnicas, para entendimento sobre a situação atual da organização na área de segurança cibernética e quais investimentos devem ser feitos para eliminar os riscos.

5 CYBER KILL CHAIN

A principal função de um caçador de ameaça é impedir que o atacante alcance seu objetivo final. Para isso, ele deve entender os passos de seu adversário.

Em 2011, a empresa Lockheed Martin criou um *framework* chamado *Cyber Kill Chain*®: um modelo que descreve um ataque e é utilizado para identificação e prevenção contra atividades cibernéticas maliciosas. Esse modelo determina os estágios de atuação que um atacante percorre para alcançar o seu objetivo. A partir do momento que os analistas têm conhecimento do *modus operandi* do invasor, é mais fácil entender em que etapa aquela atividade maliciosa se encontra, sem a necessidade de saber exatamente como executar.

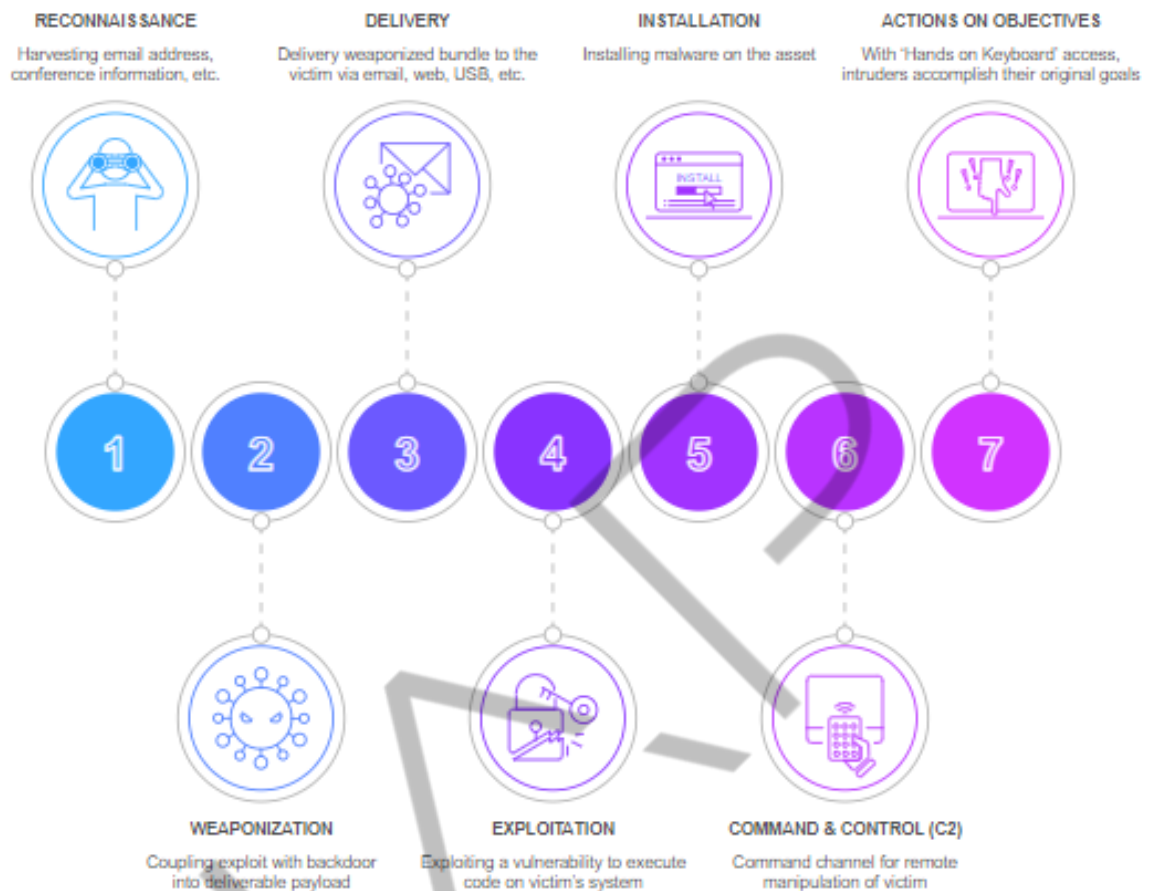


Figura 4 – *Cyber Kill Chain®*
Fonte: Lockheed Martin (2021)

Esse nome deriva de *Kill Chain*, um termo militar que em tradução literal seria algo como “Corrente de Matar” e está relacionado à estrutura de um ataque militar. Para que o ataque seja bem-sucedido, essa “corrente” deve possuir todos os elos intactos. A principal função da defesa é criar uma fraqueza para que a “corrente” seja quebrada e o ataque, cessado.

5.1 Reconnaissance

Etapa em que o atacante busca informações sobre o alvo de forma ativa ou passiva, efetuando a busca por e-mails, portas abertas em dispositivos na rede do alvo, mapeamento de página web, busca de informações utilizando indexadores de páginas, redes sociais, etc.

5.2 Weaponization

Nesta fase define-se quais ferramentas e ataques serão empregados. Utiliza-se os dados obtidos na fase anterior, para possibilitar a exploração da vulnerabilidade com um *exploit* útil para o cenário.

5.3 Delivery

A etapa *delivery* anda em conjunto com a anterior. Enquanto define-se como o alvo será explorado, é discutida a viabilidade da entrega do artefato. Nesse momento, é escolhido o modo pelo qual a carga útil (*payload*) será enviada para o alvo: web, USB, e-mail, entre outros.

5.4 Exploitation

Neste estágio, a exploração é realizada. Significa que o *exploit* foi executado no dispositivo e a ferramenta conseguiu conexão entre o alvo e o atacante.

5.5 Installation

É a fase em que o *malware* se instala no dispositivo. A partir desse momento, mesmo que a conexão seja perdida, ela pode ser estabelecida novamente pelo atacante sem a necessidade de uma nova exploração.

5.6 Command & Control

É estabelecido um comando e um controle de modo a se ter controle remoto sobre a vítima, concentrando todos os alvos explorados para possíveis movimentos laterais.

5.7 Actions on Objectives

Assim que a conexão estiver estabelecida com o alvo e existir a possibilidade de uma reconexão por motivos de queda de ligação, o atacante vai em busca de seus objetivos.

Outras empresas criaram “modificações” com base no *Cyber Kill Chain*® adaptando às suas visões, mas não deixando que sua essência fosse perdida. Um exemplo disso é o *framework Unified Kill Chain*, que foi criado pelo pesquisador Paul Pols e é uma combinação dos elementos do *Cyber Kill Chain*, da Lockheed Martin, e do *ATT&CK*, da Mitre. Veja a Figura “*Unified Kill Chain*”, que retrata esse *framework*.

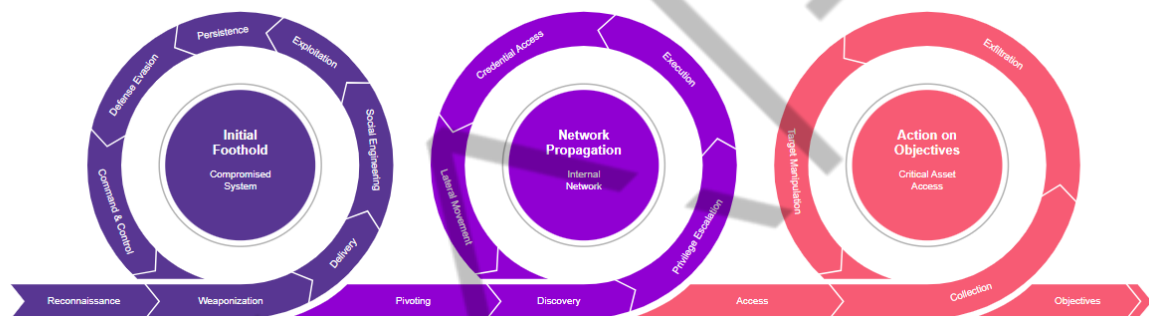


Figura 5 – *Unified Kill Chain*
Fonte: Paul Pols (2021)

Todas essas etapas não são lineares. O atacante, ao realizar qualquer ação, pode e deve voltar para outros passos a fim de encontrar mais dados e informações para avançar no ataque. Sendo assim, o caçador de ameaça deve identificar esses passos do atacante para quebrar a corrente do ataque.

6 THREAT INTELLIGENCE

Threat Intelligence, ou Inteligência de Ameaças, são dados coletados sobre ameaças. Esses dados serão processados e analisados e, posteriormente, servirão para entender os comportamentos do atacante a fim de traçar informações que resultarão em tomadas de decisão mais ágeis, além de auxiliar na criação de mecanismos de defesa contra esses ataques e, principalmente, identificar ataques não conhecidos.

A maioria das organizações está focada em análise de alertas já existentes em IPS, *firewalls*, antivírus, etc. Porém, essa equipe pode fortalecer muito as barreiras de

segurança de sua organização, uma vez que algumas empresas possuem especificidades em seus ambientes.

6.1 Ciclo de vida

O ciclo de vida da inteligência de ameaças é um processo que tem como finalidade transformar os dados brutos em informações, para que todas as equipes de segurança cibernética possam ser beneficiadas em suas áreas, de modo a tornar os seus processos ainda mais eficientes contra ameaças virtuais.

As ameaças estão em constante mudança, exigindo que as organizações se adaptem rapidamente para tomar contramedidas. O ciclo de inteligência vai fornecer uma estrutura que permitirá às equipes evoluírem e responderem da melhor forma possível.

Esse ciclo possui seis etapas, que veremos nos tópicos a seguir.

6.1.1 Requisitos

Etapa primordial para o ciclo de vida, pois define o roteiro que será seguido para uma inteligência sobre uma ameaça específica. Durante essa fase, serão planejados os objetivos e a metodologia que será utilizada para atender ao pedido de inteligência. Também serão definidas as perguntas que deverão ser respondidas ao final do relatório.

6.1.2 Coleta

A equipe iniciará a coleta de dados – nos tráfegos de rede, *logs*, sites de buscas, fóruns, mídia social, blogs especialistas, sites de compartilhamento de ataques e em outras fontes – que serão utilizados posteriormente. Nessa fase, é coletada a maior quantidade possível de dados sobre o que será investigado, e estes dados poderão ser descartados na fase seguinte.

6.1.3 Processamento

Depois que os dados brutos forem coletados, eles serão encaminhados para o processamento e reunidos para futura análise. Será feita a organização dos dados, tradução de informações e avaliação da relevância do dado coletado assim como sua confiabilidade.

6.1.4 Análise

Com os dados processados, a equipe fará uma análise completa em busca das respostas definidas na fase “requisitos”.

6.1.5 Disseminação

Nessa fase, é redigido um relatório em um formato acessível e abrangente a todos os envolvidos direta e indiretamente nesse processo. Na maioria dos casos, esses relatórios são apresentados de forma concisa, sem muitos termos técnicos e com poucas páginas ou alguns *slides*, pois o foco é não apenas disseminar a informação, mas também fazer com que ela seja entendida e incorporada às práticas cotidianas dos ambientes aos quais se destine.

6.1.6 Retorno

Esta é a fase final do ciclo de vida da inteligência. Envolve obter um retorno sobre as ações realizadas, bem como sobre o relatório fornecido. São apontados ajustes referentes às operações, implementações e mudanças de prioridades sobre as ações e possíveis alterações para outros relatórios de inteligência de ameaças.

7 TIPOS DE INTELIGÊNCIA DE AMEAÇAS

A Inteligência de Ameaças é dividida em três tipos, conforme pode ser observado na Figura “Tipos de Inteligência de Ameaças”.

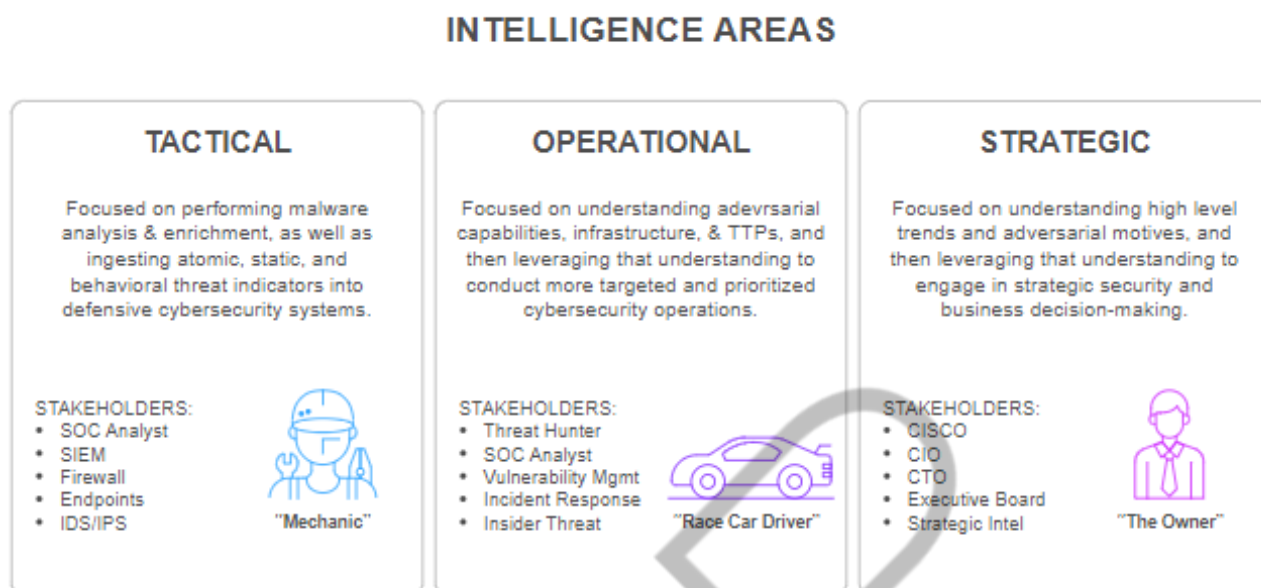


Figura 6 – Tipos de Inteligência de Ameaças
Fonte: CrowdStrike (2021)

7.1 Tática

Esse tipo de inteligência é focado em identificar indicadores de comprometimento (IOCs), que podem ser encontrados em bases de dados ou criados pela equipe para um ambiente específico. Também é responsável por aplicar atualizações de segurança em *endpoints*.

7.2 Operacional

Responsável por determinar detalhes sobre os ataques, analisando o TTPs que o responsável pela ameaça cibernética utilizou em seu ambiente. Com essa análise é possível fornecer o contexto sobre o que o adversário planeja.

Uma função muito importante a respeito de sua análise é descobrir possíveis impactos adicionais dos ataques: exfiltração de dados, outras brechas de segurança, se o atacante ainda está na rede etc.

7.3 Estratégica

Esse elemento pode ser considerado o topo da pirâmide de inteligência de ameaças. Nele se encontram os profissionais responsáveis pelo planejamento, organização, controle, alocação de recursos e definição dos parâmetros de ação, ou seja, tudo que envolve gestão de estratégia.

8 MITRE ATT&CK

A organização MITRE lançou, entre 2013 e 2015, um *framework* chamado ATT&CK, sigla para *Adversarial Tactics, Techniques & Common Knowledge* (Táticas, Técnicas e Conhecimento Comum dos Inimigos), com o intuito de descrever e classificar os comportamentos de um agente malicioso em um ataque, bem como auxiliar as equipes de defesa.

Possui uma estrutura em forma de matriz, na qual é possível observar as técnicas e táticas de um atacante. Atualmente, existem três divisões:

- **Matriz Enterprise:** formada por técnicas e táticas para os sistemas operacionais Windows, Linux e MacOS. Disponível em: <<https://attack.mitre.org/matrices/enterprise/>>.
- **Matriz Mobile:** formada por técnicas e táticas para dispositivos móveis. Disponível em: <<https://attack.mitre.org/matrices/mobile/>>.
- **Matriz PRE:** formada por ações que antecedem as da matriz ATT&CK Enterprise. Disponível em: <<https://attack.mitre.org/matrices/enterprise/pre/>>.

Version Permalink

layouts ▾ show sub-techniques hide sub-techniques help

Figura 7 – Matriz ATT&CK
Fonte: Attack. mitre (2021)

Version Permalink

Techniques
Obtain Device Cloud Backups
Remotely Track Device Without Authorization
Remotely Wipe Data Without Authorization

PDF exclusivo para VINICIUS SERAFIM DE OLIVEIRA - rm559144
vserafim_o@outlook.com

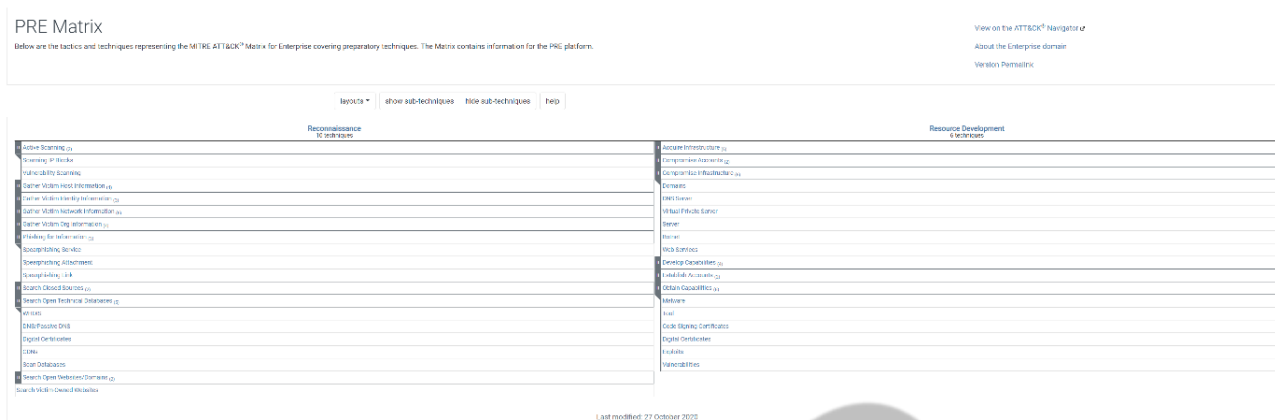


Figura 9 – PRE Matriz ATT&CK
Fonte: Attack. mitre (2021)

Com essas matrizes, as equipes de defesa são capazes de fazer um mapeamento do ataque, que ferramentas podem ser utilizadas para aplicar aquela técnica e para que fim.

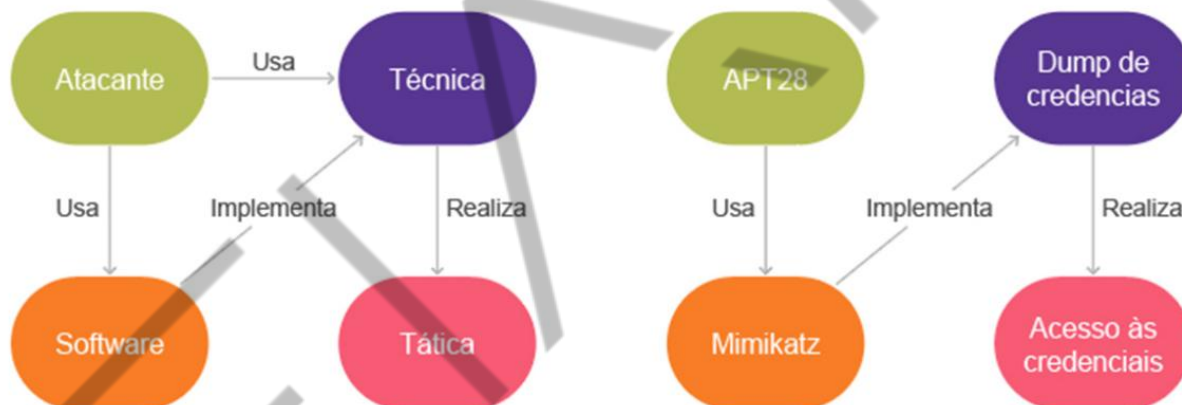


Figura 10 – Modelo ATT&CK
Fonte: Elaborado pelo autor (2021)

Ao acessar uma técnica, podemos visualizar algumas informações sobre uma subtécnica específica, como: detalhamento sobre o ataque, exemplos, formas de mitigar e como detectar, além de algumas referências.

TECHNIQUES

- Enterprise
- Reconnaissance
- Resource Development
- Initial Access
- Execution
- Persistence
- Account Manipulation
 - Exchange Email Delegate Permissions
 - Add Office 365 Global Administrator Role
 - SSH Authorized Keys**
 - Additional Cloud Credentials
- BITS Jobs
- Boot or Logon Autostart Execution
- Boot or Logon Initialization Scripts
- Browser Extensions
- Compromise Client Software Binary
- Create Account
- Create or Modify System Process
- Event Triggered Execution
- External Remote Services
- Hijack Execution Flow
- Implant Container Image
- Office Application Startup
- Pre-OS Boot

Account Manipulation: SSH Authorized Keys

Other sub-techniques of Account Manipulation (4)

Adversaries may modify the SSH `authorized_keys` file to maintain persistence on a victim host. Linux distributions and macOS commonly use key-based authentication to secure the authentication process of SSH sessions for remote management. The `authorized_keys` file in SSH specifies the SSH keys that can be used for logging into the user account for which the file is configured. This file is usually found in the user's home directory under `~/.ssh/authorized_keys`.^[1] Users may edit the system's SSH config file to modify the directives `PubkeyAuthentication` and `RSAAuthentication` to the value "yes" to ensure public key and RSA authentication are enabled. The SSH config file is usually located under `/etc/ssh/sshd_config`.

Adversaries may modify SSH `authorized_keys` files directly with scripts or shell commands to add their own adversary-supplied public keys. This ensures that an adversary possessing the corresponding private key may log in as an existing user via SSH.^[2]

Procedure Examples

Name	Description
Bundlelore	Bundlelore creates a new key pair with <code>ssh-keygen</code> and drops the newly created user key in <code>authorized_keys</code> to enable remote login. ^[4]
Skidmap	Skidmap has the ability to add the public key of its handlers to the <code>authorized_keys</code> file to maintain persistence on an infected host. ^[5]

Mitigations

Mitigation	Description
Disable or Remove Feature or Program	Disable SSH if it is not necessary on a host or restrict SSH access for specific users/groups using <code>/etc/ssh/sshd_config</code> .
Restrict File and Directory Permissions	Restrict access to the <code>authorized_keys</code> file.

Detection

Use file integrity monitoring to detect changes made to the `authorized_keys` file for each user on a system. Monitor for suspicious processes modifying the `authorized_keys` file.

Monitor for changes to and suspicious processes modifying `/etc/ssh/sshd_config`.

References

ID: T1098.004
 Sub-technique of: T1098
 Tactic: Persistence
 Platforms: Linux, macOS
 Permissions Required: Administrator, User
 Data Sources: File monitoring, Process command-line parameters, Process monitoring
 Contributors: Tony Lambert, Red Canary
 Version: 1.0
 Created: 24 June 2020
 Last Modified: 25 June 2020

Version Permalink

Figura 11 – Técnica de manipulação de contas
 Fonte: Attack. mitre (2021)

No exemplo, vemos que é possível a utilização do serviço de SSH para criar uma persistência no sistema utilizando chaves de acesso, para que o atacante possa entrar facilmente no sistema novamente.

Fazendo uma associação entre o ATT&CK e *Cyber Kill Chain*®, obtemos a situação da figura “ATT&CK e *Cyber Kill Chain*®”.



Figura 12 – ATT&CK e *Cyber Kill Chain*®
 Fonte: Elaborado pelo autor (2021)

CONCLUSÃO

Neste capítulo, vimos alguns métodos e processos que um profissional da área de caça às ameaças deve utilizar; entendendo esses tópicos, conseguimos definir como iniciar e o que procurar ao buscar ações maliciosas na rede. Também vimos alguns termos e *frameworks* que auxiliam no processo de mapeamento dessas ações, evitando que precisemos “reinventar a roda”.

EMANIP

REFERÊNCIAS

AUSTIN, B. **Threat Detection: IOC vs. IOA**. 2020. Disponível em: <<https://www.rocketcyber.com/blog/threat-detection-ioa-vs-ioc/>>. Acesso em: 12 jun. 2024.

BUKER, K. **What is Cyber Threat Intelligence?** 2021. Disponível em: <<https://www.crowdstrike.com/cybersecurity-101/threat-intelligence/>>. Acesso em: 12 jun. 2024.

CHRISANDER, M. **What is Cyber Threat Hunting? A simple guide to Threat Hunting**. 2020. Disponível em: <<https://www.logpoint.com/en/blog/threat-hunting/>>. Acesso em: 12 jun. 2024.

CROWDSTRIKE. **Indicadores de Ataque vs. Indicadores de Comprometimento**. 2021. Disponível em: <<https://www.crowdstrike.com.br/recursos/white-papers/indicadores-de-ataque-vs-indicadores-de-comprometimento/>>. Acesso em: 12 jun. 2024.

CROWDSTRIKE. **Nowhere to Hide – 2020 Threat Hunting Report Insights from The CrowdStrike Overwatch Team**. 2020. Disponível em: <<https://go.crowdstrike.com/rs/281-OBQ-266/images/Report2020OverWatchNowhereToHide.pdf>>. Acesso em: 12 jun. 2024.

CROWDSTRIKE. **Proactive Hunting – The Last Line of Defense Against The “Mega Breach”**. 2016. Disponível em: <<https://go.crowdstrike.com/rs/281-OBQ-266/images/WhitepaperProactiveHunting.pdf>>. Acesso em: 12 jun. 2024.

CROWDSTRIKE. **Research & Threat Intel**. 2021. Disponível em: <<https://www.crowdstrike.com/blog/category/threat-intel-research/>>. Acesso em: 12 jun. 2024.

DONOHUE, B. **O que é APT?** 2013. Disponível em: <<https://www.kaspersky.com.br/blog/o-que-e-apt/754/>>. Acesso em: 12 jun. 2024.

FIREEYE. **Advanced Persistent Threat Groups – Who’s who of cyber threat actors**. 2021. Disponível em: <<https://www.fireeye.com/current-threats/apt-groups.html>>. Acesso em: 12 jun. 2024.

FIREEYE. **User Guide – IOC Editor**. 2015. Disponível em: <<https://fireeye.market/assets/apps/S7cWpi9W//9cb9857f/ug-ioc-editor.pdf>>. Acesso em: 12 jun. 2024.

HUNTSMAN. **Threat Hunting using MITRE ATTACK**. 2020. Disponível em: <<https://www.huntsmansecurity.com/blog/threat-hunting-using-mitre-attack/>>. Acesso em: 12 jun. 2024.

LEIDEN-DELFT-ERASMUS. **Cyber Security Academy**. [s.d.] Disponível em: <<https://www.leiden-delft-erasmus.nl/nl/cyber-security-academy>>. Acesso em: 12 jun. 2024.

LOCKHEED MARTIN. **The Cyber Kill Chain**. 2021. Disponível em: <<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>>. Acesso em: 12 jun. 2024.

MITRE ATT&CK. **Home Page**. 2021. Disponível em: <<https://attack.mitre.org/>>. Acesso em: 12 jun. 2024.

ROMAN, D. et al. **TTP-Based Hunting**. 2020. Disponível em: <<https://www.mitre.org/publications/technical-papers/ttp-based-hunting>>. Acesso em: 12 jun. 2024.

TASCHLER, S. **What is Cyber Threat Hunting?** 2021. Disponível em: <<https://www.crowdstrike.com/cybersecurity-101/threat-hunting/>>. Acesso em: 12 jun. 2024.

GLOSSÁRIO

SOC	<i>Security Operations Center</i> (Centro de Operações de Segurança).
TTP	Táticas, Técnicas e Procedimentos.
IOC	<i>Indicator of Compromise</i> (Indicador de Comprometimento).
IOA	<i>Indicator of Attack</i> (Indicador de Ataque).
EDR	<i>Endpoint Detection and Response</i> (Ponto Final de Detecção e Resposta).
SIEM	<i>Security Information and Event Management</i> (Informações de Segurança e Gerenciamento de Eventos).
<i>Framework</i>	Conjunto de ferramentas ou procedimentos utilizados para solucionar um problema.